Prescripto AI 2.0 — Complete API Specification Dossier

Document ID: `DOC-08-API`
Classification: Academic Engineering Dossier
Canonical Spec Reference: backend/OPENAPI.yaml, docs/API-CONTRACT.md
Date of Extraction: November 4, 2026

---

1. Global API Standards & Error Envelopes

1.1. Base URL & Protocol

- **Production API Base:** `https://prescripto-2-0.onrender.com/api/v1`
- **Local Development Base:** `http://localhost:8000/api/v1`
- **Transport:** HTTPS required in production.
- **Header Correlation:** All responses include `X-Request-ID: <UUIDv4>` for end-to-end tracing across reverse proxies, backend logs, and client interceptors.

1.2. Unified Error Envelope Contract

Per docs/ERROR-CONTRACT.md, every non-2xx HTTP error strictly returns:

```
{
  "error": {
    "code": "RESOURCE_NOT_FOUND",
    "message": "Prescription document 7b1c4e92-... was not found",
    "request_id": "c3a19b02-581d-44a6-9812-32a265b7501a"
  }
}
```

Common error codes: `MALFORMED_REQUEST` (400), `INVALID_CREDENTIALS` (401), `INSUFFICIENT_ROLE` (403), `RESOURCE_NOT_FOUND` (404), `IDEMPOTENCY_CONFLICT` (409), `RATE_LIMIT_EXCEEDED` (429), `INTERNAL_ERROR` (500), `SERVICE_UNAVAILABLE` (503).

---

2. System, Health & Discovery Endpoints

`GET /` — Root Application & API Discovery

- **Authentication:** None (Public).
- **Behavior:** If requested with header `Accept: text/html` and built frontend assets exist, serves `web/dist/index.html`. If requested with `Accept: application/json` or parameter `?format=json`, returns discovery JSON:

```
{
  "name": "Prescripto AI 2.0 API",
  "version": "1.0.0",
  "status": "healthy",
  "environment": "production",
  "docs_url": "/docs",
  "openapi_url": "/openapi.json",
  "health_url": "/health",
  "database_health_url": "/health/db",
  "api_v1_base": "/api/v1"
}
```

`GET /health` — System Health Diagnostic Probe

- **Authentication:** None (Public).
- **Purpose:** High-level health check verifying PostgreSQL connection, S3 storage access, and analysis worker heartbeat.
- **Success Response (200 OK):**

```
{
  "database": "ok",
  "object_storage": "ok",
  "worker_heartbeat": "ok"
}
```

`GET /health/db` — Relational Database Health & Connection Pool Probe

- **Authentication:** None (Public).
- **Purpose:** Probes database query latency, active SQL dialect, driver name, server version, and pool connection counters.
- **Success Response (200 OK):**

```
{
  "status": "healthy",
  "database": "connected",
  "dialect": "postgresql",
  "driver": "psycopg2",
  "server_version": "16.4",
  "pool": {
    "size": 10,
    "checkedin": 1,
    "checkedout": 0,
    "overflow": 0
  },
  "timestamp": "2026-11-04T12:00:00.000Z"
}
```

---

3. Authentication & User Management Endpoints (`/api/v1/auth`)

`POST /api/v1/auth/doctor/login` — Clinician & Staff Login

- **Authentication:** None (Public).
- **Request Body:**

```
{
  "email": "doctor.sharma@prescripto.local",
  "password": "DoctorPass123!"
}
```

- **Success Response (200 OK):**

```
{
  "access_token": "eyJhbGciOiJSUzI1NiIs...",
  "refresh_token": "eyJhbGciOiJSUzI1NiIs...",
  "token_type": "bearer",
  "expires_in": 900,
  "user": {
    "id": "e2a4c102-1845-4df8-8092-234b6b643a12",
    "username": "doctor_sharma",
    "email": "doctor.sharma@prescripto.local",
    "role": "REVIEWER"
  }
}
```

`POST /api/v1/auth/send-otp` — Patient Mobile OTP Dispatch

- **Authentication:** None (Public).
- **Request Body:**

```
{
  "phone_number": "9876543210"
}
```

- **Success Response (200 OK):**

```
{
  "status": "sent",
  "phone_number": "9876543210",
  "mock_otp": "123456",
  "expires_in_seconds": 300
}
```

`POST /api/v1/auth/verify-otp` — Patient OTP Verification

- **Authentication:** None (Public).
- **Request Body:**

```
{
  "phone_number": "9876543210",
  "otp": "123456",
  "name": "Ramesh Patel"
}
```

- **Success Response (200 OK):** Returns RS256 token pair with `role: "PATIENT"`.
- **Rate Limiting:** Enforces sliding-window limit (max 5 consecutive failures per phone number). Returns `429 Too Many Requests` on violation.

`POST /api/v1/auth/refresh` — Asymmetric Token Rotation

- **Authentication:** None (Refresh token provided in body).
- **Request Body:**

```
{
  "refresh_token": "eyJhbGciOiJSUzI1NiIs..."
}
```

- **Success Response (200 OK):** Issues fresh access token and rotates refresh token.

`GET /api/v1/auth/me` — Authenticated User Profile

- **Authentication:** Bearer JWT required.
- **Success Response (200 OK):** Returns user ID, username, email, role, and active status.

---

4. Prescription Ingestion Endpoints (`/api/v1/prescriptions`)

`POST /api/v1/prescriptions` — Prescription Ingestion

- **Authentication:** Bearer JWT (`OPERATOR`, `REVIEWER`, `ADMIN`, `PATIENT`).
- **Headers:** `Idempotency-Key: <UUIDv4>` (Mandatory).
- **Request Format:** `multipart/form-data`:
- `file`: Image file bytes (JPEG/PNG/TIFF, max 20 MB).
- `patient_ref`: Optional de-identified patient identifier.
- **Success Response (202 Accepted):**

```
{
  "prescription_id": "7b1c4e92-3490-410a-bcf9-a681c201e891",
  "analysis_id": "d4a98124-7128-48b0-8f92-58129ac10243",
  "status": "PENDING",
  "created_at": "2026-11-04T12:05:00.000Z",
  "tracking_url": "/api/v1/analyses/d4a98124-7128-48b0-8f92-58129ac10243"
}
```

`GET /api/v1/prescriptions` — List Prescriptions

- **Authentication:** Bearer JWT.

- **Scope:** Patients receive only their associated prescriptions. Clinicians and Admins receive all prescriptions across the clinic.
- **Query Parameters:** `limit` (default 20), `offset` (default 0), `status` (optional filter).

`GET /api/v1/prescriptions/{id}` — Prescription Details

- **Authentication:** Bearer JWT.
- **Success Response (200 OK):**


```
{
  "id": "7b1c4e92-3490-410a-bcf9-a681c201e891",
  "patient_ref": "PAT-9876",
  "mime_type": "image/jpeg",
  "file_size_bytes": 1048576,
  "file_hash_sha256": "3a8f9c1b...",
  "status": "STORED",
  "created_at": "2026-11-04T12:05:00.000Z",
  "image_url": "/api/v1/storage/prescriptions/7b1c4e92-.../original.jpg?expires=1793774000&signa
}
```


`DELETE /api/v1/prescriptions/{id}` — Verifiable Deletion Request

- **Authentication:** Bearer JWT (Restricted to `Role.ADMIN`).
- **Success Response (202 Accepted):** Enqueues a verifiable deletion job under DPDPA 2023.

---

5. Clinical Analysis & Review Endpoints (`/api/v1/analyses`)

`GET /api/v1/analyses/{id}` — Pipeline Polling Endpoint

- **Authentication:** Bearer JWT.
- **Success Response (200 OK):**


```
{
  "id": "d4a98124-7128-48b0-8f92-58129ac10243",
  "document_id": "7b1c4e92-3490-410a-bcf9-a681c201e891",
  "status": "REQUIRES_REVIEW",
  "current_stage": "REPORT_ASSEMBLY",
  "review_required": true,
  "review_reasons": ["SAFETY_FINDING_PRESENT", "AMBIGUOUS_MEDICATION_DETECTED"],
  "created_at": "2026-11-04T12:05:00.000Z",
  "completed_at": "2026-11-04T12:05:04.250Z"
}
```


`GET /api/v1/analyses/{id}/result` — Clinical Extraction & Safety Report

- **Authentication:** Bearer JWT.
- **Success Response (200 OK):**

```
{
  "analysis_id": "d4a98124-7128-48b0-8f92-58129ac10243",
  "status": "REQUIRES_REVIEW",
  "medications": [
    {
      "id": "184b2c01-7290-49a1-8902-192837465012",
      "line_index": 0,
      "name": {
        "raw": "Dolo 650",
        "state": "CLEAR",
        "confidence": 0.96
      },
      "strength": {
        "raw": "650mg",
        "state": "CLEAR",
        "confidence": 0.98
      },
      "dose": {
        "raw": "1 tab",
        "state": "CLEAR",
        "confidence": 0.95
      },
      "frequency": {
        "raw": "TDS",
        "state": "CLEAR",
        "confidence": 0.92
      },
      "duration": {
        "raw": "5 days",
        "state": "CLEAR",
        "confidence": 0.94
      },
      "instructions": {
        "raw": "After food",
        "state": "CLEAR",
        "confidence": 0.90
      },
      "normalization": {
        "status": "RESOLVED",
        "matched_brand": "Dolo 650",
        "generic_name": "Paracetamol",
        "active_ingredients": ["Paracetamol"]
      }
    }
  ],
  "findings": [
    {
      "check_type": "DUPLICATE_MEDICATION",
      "finding_key": "dup_med_dolo_combiflam",
      "finding_status": "POTENTIAL",
```

```
      "evidence_text": "Duplicate active ingredient detected: 'Dolo 650' and 'Combiflam' share a
      "source_name": "PRESCRIPTO_DETERMINISTIC_RULES"
    }
  ],
  "review_required": true
}
```

`POST /api/v1/analyses/{id}/review` — Clinician Review Sign-Off

- **Authentication:** Bearer JWT (`REVIEWER` or `ADMIN`).
- **Request Body:**

```
{
  "finding_decisions": [
    {
      "finding_id": "9a812041-8912-4ba0-8012-384756291048",
      "action": "APPROVE",
      "notes": "Patient advised to stagger doses by 6 hours."
    }
  ],
  "general_notes": "Reviewed and confirmed prescription text against scan."
}
```

- **Success Response (200 OK):** Transitions analysis status to `REVIEWED_COMPLETE` . Subsequent modifications are rejected with HTTP 409 Conflict.

`PATCH /api/v1/analyses/{id}/medications` — Clinician Inline Drug Correction

- **Authentication:** Bearer JWT (`REVIEWER` or `ADMIN`).
- **Request Body:**

```
{
  "medication_id": "184b2c01-7290-49a1-8902-192837465012",
  "name": "Augmentin 625 Duo",
  "strength": "625mg",
  "frequency": "Twice daily",
  "instructions": "After meals"
}
```

- **Success Response (200 OK):** Updates the record, recalculates normalization, and logs a clinician correction audit event.

---

6. Patient Directory & Timeline Endpoints (`/api/v1/patients`)

`GET /api/v1/patients/search` — Search Patients

- **Authentication:** Bearer JWT (`REVIEWER` or `ADMIN`).
- **Query Parameters:** `q` (Search string matching name, phone number, or external patient ID).

`POST /api/v1/patients` — Register New Patient

- **Authentication:** Bearer JWT (`OPERATOR` , `REVIEWER` , `ADMIN`).
- **Request Body:**

```
{
  "patient_id": "PAT-2026-0812",
  "name": "Kavita Rao",
  "age": 42,
  "gender": "FEMALE",
  "phone_number": "9876543210",
  "allergies": "Penicillin, Sulfa",
  "medical_history": "Type 2 Diabetes, Hypertension"
}
```

- **Success Response (201 Created):** Returns created patient record with assigned UUID.

`GET /api/v1/patients/{id}` — Historical Clinical Timeline

- **Authentication:** Bearer JWT.
- **Success Response (200 OK):** Returns patient clinical profile and chronological list of all previous prescriptions, analyses, and clinician sign-offs.

---

7. Protected Storage Streaming (`/api/v1/storage`)

`GET /api/v1/storage/{key:path}` — Stream Stored Image Scan

- **Authentication:** Ephemeral HMAC-SHA256 signature in query string: `?expires=<timestamp>&signature=<hex_signature>` .
- **Behavior:** Validates that `time.time() <= expires` and `hmac.compare_digest(expected, signature)` . Returns binary image stream (`image/jpeg` , `image/png`). Expired or forged signatures return `403 Forbidden` . Path traversals (`../`) return `404 Not Found` .